ESPE
UNIVERSIDAD DE LAS FUERZAS ARMADAS
INNOVACIÓN PARA LA EXCELENCIA

Departamento de Ciencias de la Computación

Ingeniería en Software

DESARROLLO DE SOFTWARE SEGURO



Unidad 1:

INTRODUCCIÓN Y ESTUDIO DE VULNERABILIDADES

Introducción

Profesor: Geovanny Cudco

TABLA DE CONTENIDOS — Unidad 1

Ruta de aprendizaje de la unidad

Temas que se abordarán desde la introducción hasta la seguridad en servidores web y bases de datos.



1 **1.1 INTRODUCCIÓN**
Visión general de la unidad, objetivos y alcance de los temas a tratar.

2 **1.1.1 QUÉ ES LA SEGURIDAD DEL SOFTWARE**
Concepto, principios y características fundamentales.

3 **1.1.2 LA IMPORTANCIA DE LA SEGURIDAD EN EL SOFTWARE**
Beneficios, impacto y razones para integrar la seguridad en el ciclo de vida del software.

4 **1.1.3 LAS VULNERABILIDADES Y SUS COSTES**
Tipos de vulnerabilidades, ejemplos y consecuencias económicas y operativas.

5 **1.1.4 GESTIÓN DE RIESGOS DE SEGURIDAD DEL SOFTWARE**
Identificación y análisis de riesgos, probabilidad e impacto, y toma de decisiones.

6 **1.1.5 PROPIEDADES DEL SOFTWARE SEGURO Y RESILIENTE**
Confidencialidad, integridad, disponibilidad, autenticación y no repudio.

7 **1.1.6 CONCEPTOS DE SEGURIDAD**
Activos, amenazas, vulnerabilidades, riesgos y controles en el software.

8 **1.1.7 SERVIDORES WEB HTTP, BASES DE DATOS**
Principales riesgos y prácticas de seguridad en aplicaciones web y sistemas de bases de datos.

Mensaje clave: la unidad construye una visión progresiva: conceptos base → vulnerabilidades → riesgo → propiedades de seguridad → seguridad web y de datos.

1.1.4 RESULTADO DE APRENDIZAJE DE LA UC 1

Resultado de aprendizaje

Comprender los fundamentos de la seguridad del software, identificando conceptos, vulnerabilidades, amenazas y riesgos que afectan al ciclo de vida del desarrollo, para analizar su impacto en la confiabilidad y resiliencia de los sistemas y aplicar directrices y estrategias de seguridad en hardware, código, diseño y arquitectura.



Fundamentos de seguridad

Comprender los conceptos esenciales de seguridad del software.

Vulnerabilidades

Identificar y analizar las vulnerabilidades en software, hardware, configuración y arquitectura.

Amenazas y riesgos

Reconocer las amenazas y evaluar su probabilidad e impacto en los sistemas.

Ciclo de vida

Considerar la seguridad en todas las fases del desarrollo, desde los requisitos hasta la operación.

Confiabilidad y resiliencia

Analizar cómo los riesgos afectan la confiabilidad y la capacidad de recuperación de los sistemas.

Estrategias de mitigación

Aplicar directrices y buenas prácticas de seguridad en hardware, código, diseño y arquitectura.

Competencias esperadas

Al finalizar la unidad, serás capaz de:

1. **Analizar** conceptos, amenazas, vulnerabilidades y riesgos en diferentes escenarios.
2. **Priorizar** los riesgos en función de su probabilidad e impacto.
3. **Proteger** aplicando controles y estrategias de seguridad adecuadas.
4. **Mejorar** la seguridad del software mediante decisiones informadas y prácticas continuas.

Mensaje clave: el objetivo de la unidad es pasar de la comprensión conceptual a la aplicación de controles de seguridad. (CISA, 2023; NIST, 2024)

La seguridad del software

es una disciplina que protege las aplicaciones a lo largo de todo su ciclo de vida para reducir vulnerabilidades y el riesgo operativo.



1. **Requisitos**
   Integrar requisitos de seguridad desde el inicio, considerando riesgos y cumplimiento.
2. **Diseño**
   Aplicar principios de seguridad y definir controles en la arquitectura y diseño.
3. **Implementación**
   Desarrollar código seguro, realizar revisiones y pruebas estáticas/dinámicas para detectar fallas.
4. **Despliegue**
   Configurar entornos de forma segura, gestionar dependencias y aplicar controles de liberación.
5. **Operación**
   Monitorear, detectar incidentes, gestionar vulnerabilidades y mantener mejoras continuas.

¿Por qué importa?

Reduce el riesgo de pérdidas económicas, interrupciones del servicio y daños a la confianza de los usuarios.

¿Qué se protege?

Activos del software: datos, servicios, procesos y reputación de la organización.

¿Frente a qué?

Amenazas como errores de desarrollo, ataques maliciosos, malas configuraciones y dependencias de terceros.

¿Cómo se logra?

Mediante controles de seguridad: prevención, detección, respuesta y recuperación.

Mensaje clave: La seguridad del software es transversal al ciclo de vida y no una actividad aislada.

(CISA, 2023; NIST, 2022)

Ciclo de vida del desarrollo de software (SDLC) con seguridad

La seguridad debe integrarse en todas las etapas del ciclo de vida para construir software más seguro y resiliente.



Beneficio de integrar seguridad temprano

Incorporar la seguridad desde las primeras etapas del SDLC proporciona importantes ventajas:

Menor coste
Corregir vulnerabilidades temprano es más económico.

Menos retrabajo
Se evitan cambios mayores en etapas avanzadas.

Menos exposición
Se reduce la probabilidad de incidentes de seguridad.

Mayor confiabilidad
Se construye software más seguro, estable y conidable.

Mensaje clave: integrar seguridad desde el inicio del SDLC reduce vulnerabilidades y costes de corrección. (NIST, 2022; CISA, 2023)

1.1 INTRODUCCIÓN — Amenazas, vulnerabilidades, riesgos y controles

1



Activo

Cualquier elemento de valor para la organización (datos, software, servicios, procesos o infraestructura).

2



Vulnerabilidad

Debilidad en el software, la configuración o el proceso que puede ser explotada por una amenaza.

3



Amenaza

Entidad, evento o condición que podría explotar una vulnerabilidad para causar un daño al activo.

4



Riesgo

Probabilidad de que ocurra una amenaza y el impacto que generaría sobre el activo si se explota la vulnerabilidad.

5



Control

Medida administrativa, técnica o física que reduce la probabilidad de que se explote la vulnerabilidad o el impacto del riesgo.

Ejemplo práctico: Formulario web público

Un formulario de contacto en un sitio web permite a los usuarios enviar mensajes.



Activo

Aplicación web y datos de los mensajes.



Vulnerabilidad

Validación de entrada débil (p. ej., campos sin sanitizar).



Amenaza

Atacante externo que envía entradas maliciosas (p. ej., inyección de código).



Riesgo

Acceso no autorizado o alteración de datos de la aplicación.



Control

Validación de entradas, WAF (Web Application Firewall) y consultas parametrizadas.

Relaciones clave



Exposición
Una vulnerabilidad expone al activo a una amenaza.



Impacto
El riesgo considera el posible daño sobre el activo.



Probabilidad
Depende de la existencia de la amenaza y de la facilidad de explotación de la vulnerabilidad.



Mitigación
Los controles reducen la probabilidad y/o el impacto del riesgo.



Mensaje clave: el riesgo aparece cuando una amenaza puede explotar una vulnerabilidad sobre un activo; los controles reducen probabilidad o impacto.

(NIST, 2024; OWASP, 2025)

1.1.1 QUÉ ES LA SEGURIDAD DEL SOFTWARE — Definición

Disciplina orientada a diseñar, desarrollar, desplegar y mantener software capaz de resistir ataques, errores y condiciones adversas, reduciendo vulnerabilidades y riesgo.



Seguridad del software

Propiedades y prácticas incorporadas al producto de software para prevenir, detectar y responder a amenazas.

Ciberseguridad

Protección del ecosistema digital frente a amenazas, ataques y riesgos que afecta a personas, organizaciones y sistemas.

Seguridad de aplicaciones

Protección de aplicaciones durante su ciclo de vida (desarrollo, pruebas, despliegue y ejecución) para evitar y mitigar vulnerabilidades.

Seguridad de la información

Protección de la confidencialidad, integridad y disponibilidad de la información, independientemente del medio o formato.

Idea clave: la seguridad debe diseñarse, no añadirse al final.

(Scarfone et al., 2022; CISA, 2023)

1.1.1 QUÉ ES LA SEGURIDAD DEL SOFTWARE — Relación con otras disciplinas



Seguridad del software

Se centra en el producto y su ciclo de vida.

Busca prevenir, identificar y mitigar vulnerabilidades a lo largo de todo el ciclo de vida del software (diseño, desarrollo, pruebas, despliegue y mantenimiento).



Ciberseguridad

Protege organizaciones, redes, servicios y usuarios.

Se enfoca en defender los sistemas de información, redes, infraestructura y usuarios frente a amenazas en el entorno digital, aplicando controles técnicos, administrativos y físicos.



Seguridad de aplicaciones (AppSec)

Prácticas y herramientas para proteger aplicaciones.

Conjunto de prácticas, estándares y herramientas orientadas a prevenir y detectar vulnerabilidades específicas en aplicaciones durante su desarrollo y operación.



Seguridad de la información

Preserva confidencialidad, integridad y disponibilidad de los datos.

Se enfoca en proteger la información de la organización, garantizando su confidencialidad, integridad y disponibilidad, independientemente del medio en el que se almacene o procese.

Puntos en común



Gestión de riesgos
Identificación, valoración y priorización.



Controles
Implementación de medidas técnicas, administrativas y físicas.



Monitoreo
Detección continua de amenazas y anomalías.



Respuesta
Acciones ante incidentas de seguridad.



Cumplimiento
Alineación con normas, estándares y regulaciones.

Ejemplo académico



Un sistema de matrículas requiere:

- **Código seguro** para evitar vulnerabilidades (seguridad del software).
- **Infraestructura protegida** para mantener la disponibilidad (ciberseguridad).
- **Pruebas de seguridad de aplicaciones (AppSec)** para detectar fallos.
- **Protección de los datos de estudiantes** (seguridad de la información).



Mensaje clave: la seguridad del software forma parte de un ecosistema más amplio, pero conserva un foco directo sobre el producto.

(NIST, 2024; OWASP, 2025)

1.1.1 QUÉ ES LA SEGURIDAD DEL SOFTWARE — Objetivos y beneficios

Objetivos principales

La seguridad del software busca gestionar los riesgos para:

1. **Prevenir**
   Evitar la introducción de vulnerabilidades y reducir la superficie de ataque.
2. **Detectar**
   Identificar oportunamente amenazas, vulnerabilidades y comportamientos anómalos.
3. **Responder**
   Contener y mitigar incidentes de seguridad de forma efectiva.
4. **Recuperarse**
   Restablecer el servicio y aprender de los incidentes para mejorar continuamente.

Reducir vulnerabilidades

Disminuir las debilidades en el software antes de su puesta en producción.

Proteger la información

Garantizar la confidencialidad, integridad y disponibilidad de los datos y transacciones.

Mantener la disponibilidad

Asegurar la continuidad del servicio y minimizar el tiempo de inactividad.

Aumentar la confianza

Generar confianza en usuarios, clientes y partes interesadas en el software y la organización.

Reducir costes

Disminuir la cantidad de incidentes, los gastos de recuperación y las posibles sanciones regulatorias.

Cumplir requisitos

Satisfacer normas, políticas, regulaciones y buenas prácticas de seguridad aplicables al software.

Beneficios para la organización

La seguridad del software aporta valor y fortalece el desempeño del negocio:

- **Mayor productidad**
  Menos interrupciones y mayor eficiencia en los procesos.
- **Mejor reputación**
  Mayor confianza de clientes, usuarios y socios estratégicos.
- **Mayor resiliencia**
  Capacidad de adaptarse y seguir operando ante amenazas y cambios del entorno.

Mensaje clave: Invertir en seguridad del software mejora confiabilidad, continuidad y valor para el negocio. (IBM, 2026; CISA, 2023)

1.1.1 QUÉ ES LA SEGURIDAD DEL SOFTWARE — Seguridad por diseño

Seguridad por diseño:

integrar requisitos, amenazas, controles y verificación desde las primeras fases del ciclo de vida.



Enfoque reactivo

La seguridad se aborda después de que ocurren los problemas.

Descubrir
Identificar vulnerabilidades después del despliegue.

Corregir
Aplicar parches y correcciones de emergencia.

Recuperar
Restaurar servicios y mitigar el impacto del incidente.

Mayor coste
Las correcciones suelen ser más caras.

Retrabajo
Se requiere rediseño y cambios en el código.

Presión de tiempo
Se trabaja bajo urgencia y con menos análisis.

Mayor exposición
Más tiempo expuesto a amenazas.

Enfoque preventivo

La seguridad se integra desde el inicio del ciclo de vida.

Diseñar
Integrar requisitos de seguridad y modelar amenazas desde el inicio.

Verificar
Comprobar controles y validar la seguridad durante el desarrollo y pruebas.

Monitorizar
Supervisar, detectar anomalías y mejorar de forma continua en producción.

Menor exposición
Se reducen las vulnerabilidades desde el inicio.

Controles tempranos
Se incorporan controles en todas las fases del ciclo de vida.

Automatización
Se integran pruebas y análisis automáticos de seguridad.

Mejora continua
Se aprende, se mide y se fortalecen los controles.

Prácticas clave:

1. **Modelado de amenazas**
   Identificar y analizar amenazas desde el diseño.
2. **Validación de entradas**
   Evitar datos no confiables y validar correctamente.
3. **Mínimo privilegio**
   Conceder solo los permisos necesarios.
4. **Gestión de dependencias**
   Controlar y actualizar librerías y componentes.
5. **Pruebas de seguridad**
   Aplicar análisis estático, dinámico y pruebas de penetración.
6. **Hardening**
   Configurar y endurecer el software, servidores y entornos.

Mensaje clave: diseñar seguridad desde el inicio reduce exposición, retrabajo y coste de corrección. (CISA, 2023; NIST, 2022)

1.1.2 LA IMPORTANCIA DE LA SEGURIDAD EN EL SOFTWARE — Panorama actual de amenazas



31%
de las brechas
explotación de vulnerabilidades como vector de acceso inicial.

↗ +55% interanual



48%
de las brechas
involucran a terceros / cadena de suministro.

↗ +60% interanual



40%
más tasa mediana de clics exitosos en phishing móvil frente al correo electrónico.



ENISA 2024
Amenazas principales: disponibilidad, ransomware y amenazas a los datos.



Explotación de vulnerabilidades
Aprovechamiento de fallas en software, configuraciones o componentes para obtener acceso no autorizado.



Ransomware
Cifrado de sistemas y datos para exigir un rescate, con alto impacto en la continuidad del negocio.



Credenciales / Phishing móvil
Robo de credenciales mediante ingeniería social, especialmente a través de dispositivos móviles.



Terceros / Cadena de suministro
Compromiso de proveedores y componentes de terceros que impacta en toda la cadena de valor.



Mensaje clave: El panorama actual combina explotación técnica, terceros y amenazas cada vez más automatizadas.

(Verizon, 2026; ENISA, 2024)

1.1.2 LA IMPORTANCIA DE LA SEGURIDAD EN EL SOFTWARE — Prevención vs. corrección



Seguridad reactiva

Se actúa **después** de que ocurre un incidente.

Detectar después → **Contener** → **Corregir** → **Recuperar**

Mayor exposición

Las vulnerabilidades permanecen activas por más tiempo.

Retrabajo

Se requieren esfuerzos adicionales para corregir.

Interrupción operativa

Puede afectar la disponibilidad del servicio.

Presión de tiempo

Las decisiones se toman bajo presión y con mayor riesgo de error.

VS



Seguridad preventiva

Se integran controles **desde el inicio** del ciclo de vida.

Diseñar → **Prevenir** → **Verificar** → **Monitorear**

Menor exposición

Se reducen las vulnerabilidades antes de que sean explotadas.

Controles tempranos

Se aplican buenas prácticas y controles desde el diseño.

Automatización

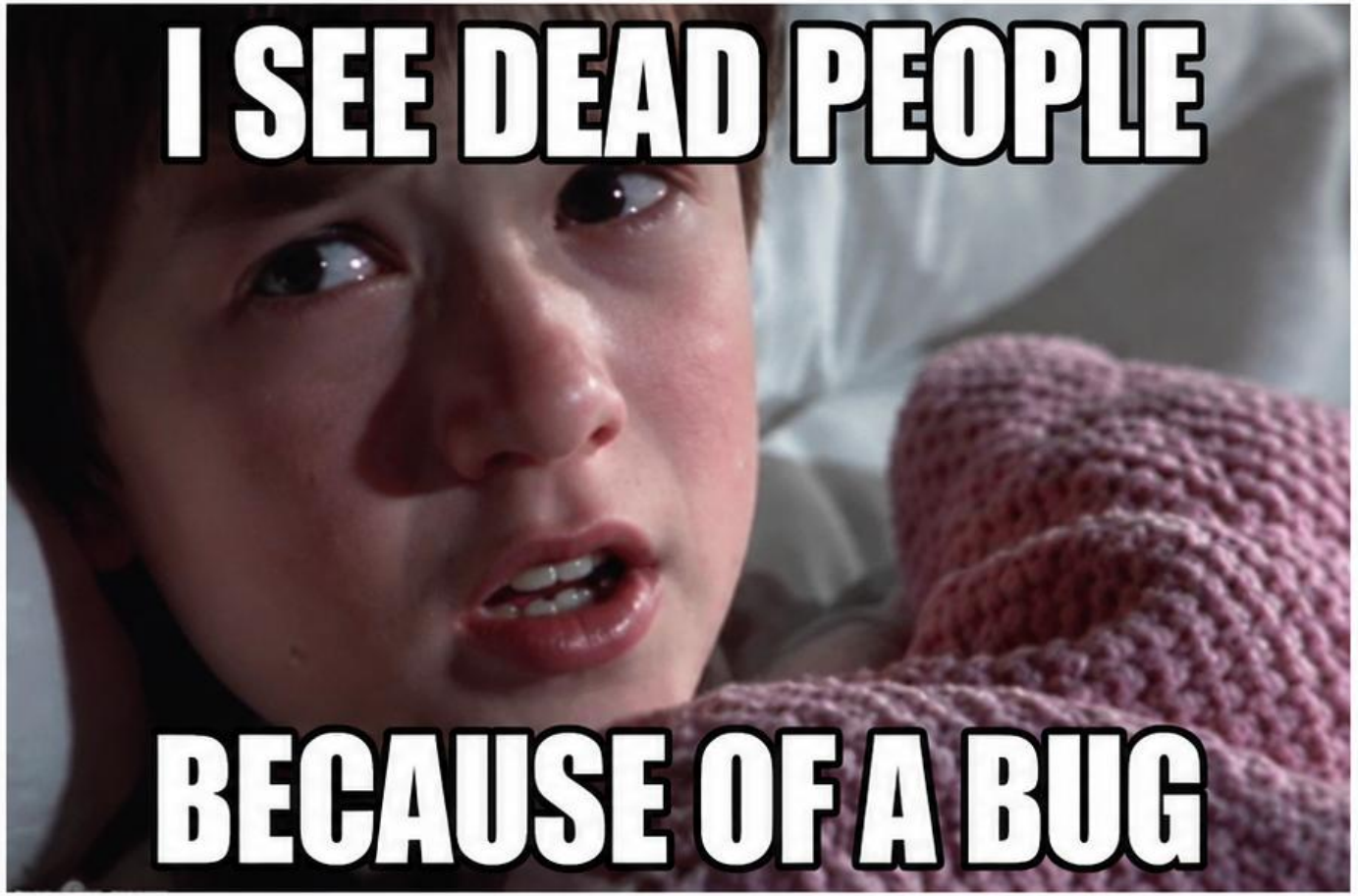
Se incorporan pruebas y análisis de seguridad automatizados.

Mejora continua

Se monitorea y evoluciona la seguridad durante todo el ciclo de vida.

Mensaje clave: Corregir vulnerabilidades antes de producción reduce exposición, retrabajo y riesgo. (Scarfone et al., 2022; CISA, 2023)

1.3 Las vulnerabilidades y sus costes



1.3 Las vulnerabilidades y sus costes

Situación Actual - ¡CRISIS!

- Las vulnerabilidades y amenazas van en aumento.
- Existe mayor cobertura mediática.



1.3 Las vulnerabilidades y sus costes

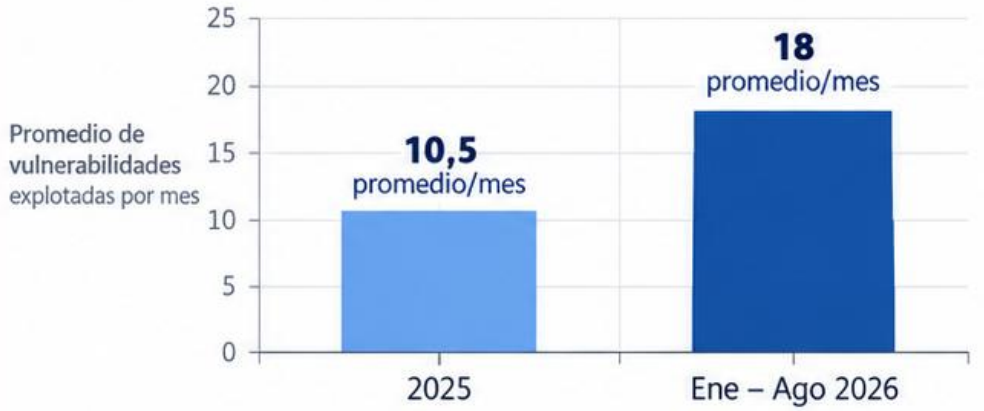
ESPE
UNIVERSIDAD DE LAS FUERZAS ARMADAS
INNOVACIÓN PARA LA EXCELENCIA

Panorama de vulnerabilidades en 2026

Vulnerabilidades divulgadas por mes (2026)



Vulnerabilidades explotadas por mes



141
vulnerabilidades explotadas
Ene – Ago 2026

0,23 %
de las vulnerabilidades divulgadas fueron observadas en explotación activa

≈66.000
CVE proyectadas para 2026
(FIRST, actualización de mitad de año)

El volumen crece rápidamente, pero la priorización debe centrarse en **riesgo y explotación real.**

Fuentes: Google Threat Intelligence Group (30 sep. 2026); FIRST Mid-Year Vulnerability Forecast (15 jun. 2026); Microsoft Digital Defense Report 2026.

1.3 Las vulnerabilidades y sus costes

OWASP Top 10:2025 – porcentajes de ocurrencia (consulta 2026)



- A01 Pérdida de control de acceso
- A02 Configuración de seguridad incorrecta
- A03 Fallas en la cadena de suministro de software
- A04 Fallas criptográficas
- A05 Inyección
- A06 Diseño inseguro
- A07 Fallas de autenticación
- A08 Fallas en la integridad del software o de los datos
- A09 Fallas en el registro, alerta y monitoreo de seguridad
- A10 Manejo inabecuado de condiciones excepcionales

Mayor participación: A01 Control de acceso (19,9%)

Le siguen A04 Fallas criptográficas (18,1%) y A05 Inyección (15,2%)

Las categorías con menor participación fueron A03 (2,3%) y A09 (2,8%)

Nota: porcentajes relativos calculados a partir de las "Total Occurrences" reportadas por OWASP Top 10:2025; las categorías pueden coexistir en una misma aplicación.

Fuente: OWASP Top 10:2025, https://top10.owasp.org/2025/ (categorías A01–A10, consulta 2026).

ESPE
UNIVERSIDAD DE LAS FUERZAS ARMADAS
INNOVACIÓN PARA LA EXCELENCIA

Gestión de vulnerabilidades mediante taxonomías

CVE, CWE, CVSS, CPE, CAPEC, KEV y EPSS

CVE
Identifica vulnerabilidades

CWE
Describe la debilidad raíz

CVSS
Puntúa severidad

CPE / NVD
Relaciona productos y contexto

CAPEC
Conecta con patrones de ataque

KEV / EPSS
Prioriza explotación real y probable

Descubrir → Clasificar → Puntuar → Priorizar → Remediar → Verificar

Fuentes: MITRE (CVE, CWE, CAPEC); NIST NVD / CPE; FIRST (CVSS v4.0, EPSS); CISA KEV; OWASP Top 10:2025; NIST SP 800-40r4.

ESPE
UNIVERSIDAD DE LAS FUERZAS ARMADAS
INNOVACIÓN PARA LA EXCELENCIA

Flujo integrado de gestión de vulnerabilidades

Una taxonomía útil conecta descubrir, priorizar y remediar

Inventariar
activos y CPE

Detectar
CVE / NVD

Analizar
CWE / CAPEC

Priorizar
CVSS + KEV + EPSS

Remediar
parches y controles

Verificar
reescaneo y cierre

Cobertura de activos

MTTR

% críticas corregidas en SLA

Principio

No basta con contar vulnerabilidades; hay que entender contexto, severidad y explotación.

Fuentes: NIST SP 800-40r4; MITRE; NIST NVD; FIRST CVSS/EPSS; CISA KEV (consulta 2026).

KEV y EPSS

Explotación real y probabilidad de ataque

ESPE
UNIVERSIDAD DE LAS FUERZAS ARMADAS
INNOVACIÓN PARA LA EXCELENCIA

CISA KEV

- Vulnerabilidades explotadas en la realidad
- Priorización inmediata
- Catálogo oficial de CISA

EPSS

- Probabilidad de explotación en 30 días
- Modelo empírico y diario
- Score 0–1 y percentil



Regla práctica: CVSS alto + KEV o EPSS alto + activo crítico = acción prioritaria.

Fuentes: CISA Known Exploited Vulnerabilities Catalog; FIRST EPSS (consulta 2026).

ESPE
UNIVERSIDAD DE LAS FUERZAS ARMADAS
INNOVACIÓN PARA LA EXCELENCIA

CWE, CAPEC y OWASP Top 10

De la causa raíz al patrón de ataque

CWE

Describe la debilidad

CAPEC

Explica cómo se explota

OWASP Top 10:2025

Agrupa riesgos frecuentes

Ejemplo: CVE → CWE-89 (SQL Injection) → CAPEC-66 → A05 Inyección

Uso en gestión

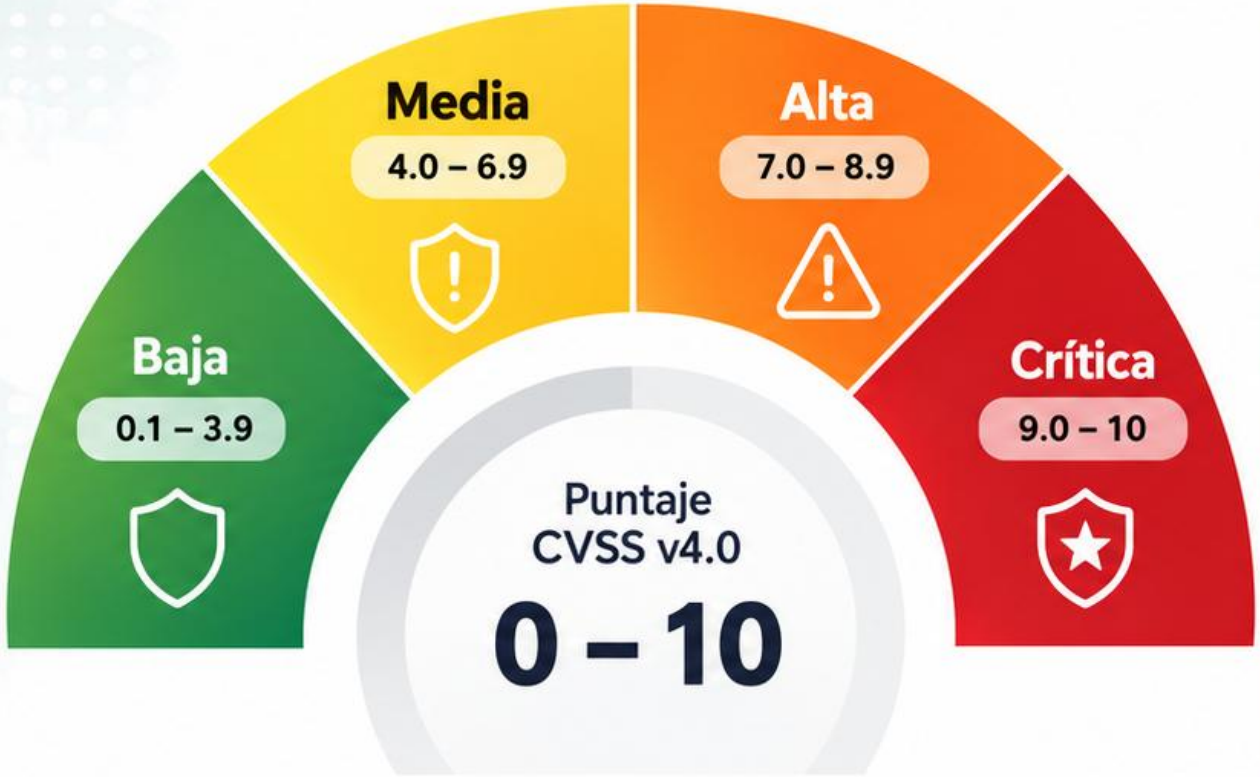
- **CWE** orienta remediación
- **CAPEC** apoya pruebas y threat modeling
- **OWASP** ayuda a comunicar riesgo

Fuentes: MITRE CWE y CAPEC; OWASP Top 10:2025 (consulta 2026).

ESPE
UNIVERSIDAD DE LAS FUERZAS ARMADAS
INNOVACIÓN PARA LA EXCELENCIA

CVSS v4.0

Puntuar severidad no es lo mismo que priorizar



Base
Características intrínsecas de la vulnerabilidad.

Threat
Contexto y explotación en el mundo real.

Environmental
Impacto según el entorno de la organización.

Supplemental
Información adicional para un análisis más completo.

Buenas prácticas: usar CVSS junto con criticidad del activo, KEV y EPSS.

Fuente: FIRST, Common Vulnerability Scoring System v4.0 User Guide y Specification (consulta 2026).

ESPE
UNIVERSIDAD DE LAS FUERZAS ARMADAS
INNOVACIÓN PARA LA EXCELENCIA

CVE, NVD y CPE

Identificar la vulnerabilidad y relacionarla con el activo

CVE

Asigna un identificador único

CVE-2026-12345

NVD

Enriquece con descripción, referencias y CVSS

CPE

Relaciona la vulnerabilidad con productos y versiones

Inventario de activos → CPE → CVE/NVD → Lista priorizada

Idea clave

- CVE dice qué vulnerabilidad es
- NVD añade contexto técnico
- **CPE** ayuda a saber dónde aplica

Fuentes: MITRE CVE; NIST NVD y CPE Dictionary (consulta 2026).

1.4 Gestión de riesgos de seguridad del software

ESPE
UNIVERSIDAD DE LAS FUERZAS ARMADAS
INNOVACIÓN PARA LA EXCELENCIA

Dato

Hecho aislado y sin contexto

```
CVE-2026-1234
CVSS: 9.8
CWE-79
2026-07-15
Product X
v1.2.3
...
```

- Valores
- Identificadores
- Atributos
- Sin significado por sí solos

Procesamiento

Información

Dato procesado, con contexto y valor

CVE-2026-1234 Crítica

- CVSS: 9.8
- CWE-79 (XSS)
- Producto: Product X
- Versión: 1.2.3
- Publicado: 15 jul. 2026

Permite priorizar, evaluar el riesgo y tomar decisiones.

1.4. Gestión de riesgos de seguridad del software



Pirámide DIKW

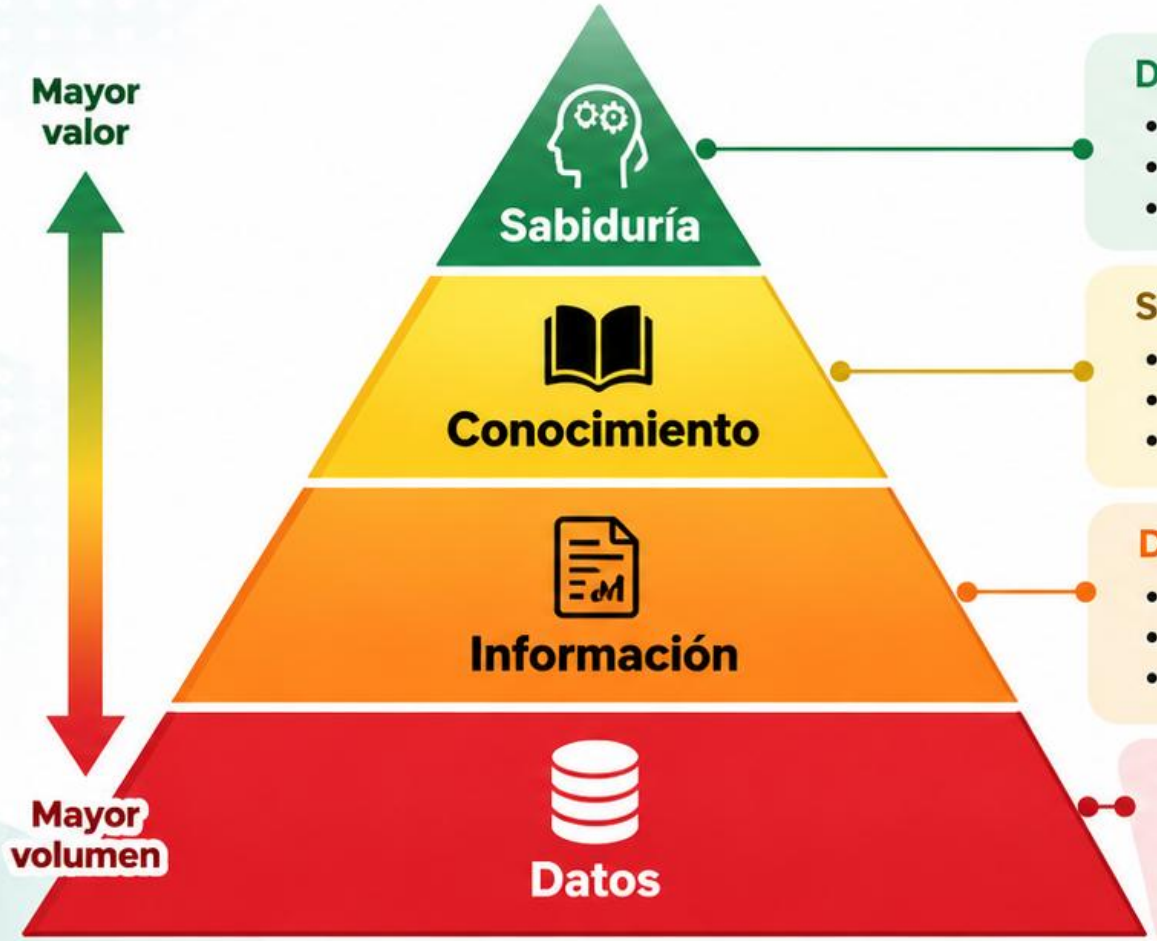
Ejemplos en seguridad

- **Datos:** registros aislados
- **Información:** contexto y relación
- **Conocimiento:** análisis del riesgo
- **Sabiduría:** acción priorizada

1.4. Gestión de riesgos de seguridad del software

ESPE
UNIVERSIDAD DE LAS FUERZAS ARMADAS
INNOVACIÓN PARA LA EXCELENCIA

Pirámide DIKW: de los datos a la sabiduría para la toma de decisiones



Decisiones y mejora continua

- Estrategia de seguridad
- Políticas y priorización
- Mitigación de riesgos

Ejemplo

Actualizar políticas, rediseñar la arquitectura, asignar recursos

Significado y contexto

- Relaciones entre vulnerabilidades
- Causas y patrones (CWE)
- Contexto del negocio

Ejemplo

CWE-79: Inyección XSS común en aplicaciones web

Datos procesados y organizados

- CVE, CVSS, vectores de ataque
- Clasificación y métricas
- Reportes y dashboards

Ejemplo

CVE-2026-1234
CVSS: 9.8 (Crítica)
Exploit disponible

Hechos sin contexto

- Registros, eventos, logs
- Observaciones individuales
- Sin interpretación

Ejemplo

IP: 192.168.1.10
Acceso fallido
Código: 500

1.4. Gestión de riesgos de seguridad del software

La información como activo

Valor para la organización

Procesos, decisiones y servicios dependen de ella.

Riesgos y amenazas

Pérdida, alteración, exposición o indisponibilidad.



INFORMACIÓN

Activo que aporta valor y debe protegerse.

Confidencialidad • Integridad • Disponibilidad

Propiedades esenciales del SGSI.

Gestión del riesgo

Identificar → evaluar → tratar → monitorear.

Proteger la información significa proteger el valor que sostiene al software y al negocio.

Fuentes: ISO/IEC 27000:2026; ISO/IEC 27001:2022.

1.4. Gestión de riesgos de seguridad del software

¿Qué es un SGSI?

Definición

Sistema de Gestión de Seguridad de la Información: marco para establecer, implementar, mantener y mejorar continuamente la seguridad de la información (ISO/IEC 27001:2022).

Propósito

Gestiona riesgos sobre la confidencialidad, integridad y disponibilidad de la información — CIA (ISO/IEC 27001:2022).



Base conceptual

Integra personas, procesos, tecnología y políticas para proteger activos de información (ISO/IEC 27000:2026).

En software

Orienta decisiones, controles y prioridades de seguridad a lo largo del ciclo de vida del software.

Objetivo: proteger el valor del negocio mediante la gestión sistemática del riesgo.

1.4. Gestión de riesgos de seguridad del software

Proceso de gestión del riesgo en un SGSI



Riesgo = Probabilidad × Impacto

Ejemplo: API expuesta con CVE crítica.

1.4. Gestión de riesgos de seguridad del software

Relación con la seguridad en el software

Requisitos	Diseño	Desarrollo	Pruebas	Despliegue	Operación
Criterios e historias de seguridad.	Threat modeling y arquitectura segura.	Revisión de código y dependencias.	SAST/DAST y validación.	Hardening y CI/CD seguro.	Monitoreo y respuesta.

El SSDF recomienda integrar prácticas seguras en todo el SDLC para reducir vulnerabilidades y sus causas raíz (NIST SP 800-218, 2022).

El SGSI aporta gobierno, criterios y controles.

1.4. Gestión de riesgos de seguridad del software

Normas y marcos que apoyan este propósito

ISO/IEC 27000:2026

Conceptos y principios del SGSI.

ISO/IEC 27001:2022

Requisitos del SGSI.

ISO/IEC 27005:2022

Gestión del riesgo.

ISO/IEC 27002:2022

Controles de seguridad.

NIST CSF 2.0 (2024)

Funciones para gestionar riesgo cibernético.

NIST SP 800-218 (2022)

Prácticas de desarrollo seguro.

Complemento útil: NIST SP 800-61r3 (2025) integra respuesta a incidentes con la gestión del riesgo.

1.4. Gestión de riesgos de seguridad del software

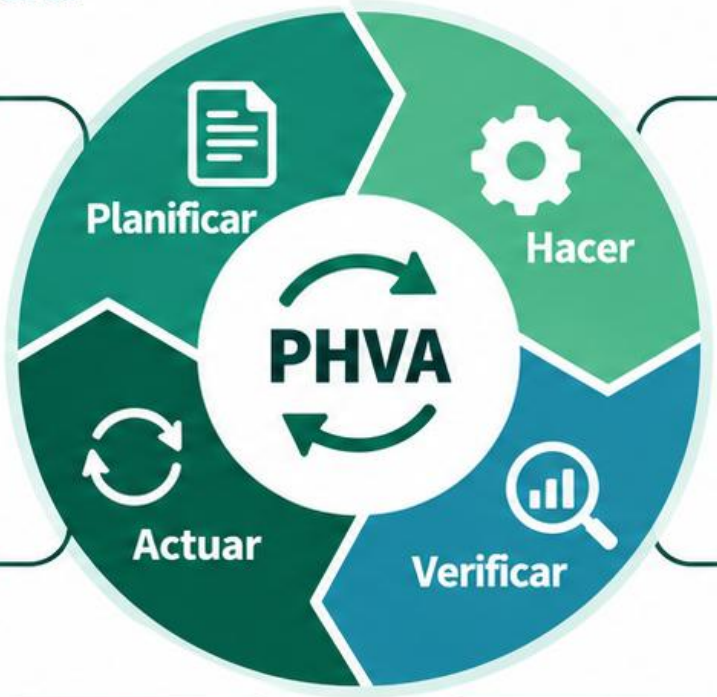
PHVA y mejora continua

Planificar

Políticas, objetivos, criterios y plan de tratamiento.

Hacer

Implementar controles y prácticas.



Actuar

Corregir, prevenir y mejorar.

Verificar

Auditar, medir y revisar incidentes.

La **mejora continua** es un requisito del SGSI (ISO/IEC 27001:2022).

La **respuesta a incidentes** debe integrarse a la gestión del riesgo (NIST SP 800-61r3, 2025).

Medir → aprender → ajustar → fortalecer

1.4. Gestión de riesgos de seguridad del software

Ejemplo 1 — Implementación de un SGSI en una API de pedidos

1. Contexto y alcance

Organización:
comercio electrónico.

Alcance SGSI:
API de pedidos, base de datos de clientes y consola administrativa.

Activos críticos:
datos personales, órdenes, credenciales, disponibilidad del servicio.

2. Método de análisis

1. Identificar activos, amenæzas y vulnerabilidades.
2. Valorar Probabilidad (1–5) e Impacto (1–5).
3. Riesgo inherente = P × I.

(ISO/IEC 27005:2022; NIST CSF 2.0, 2024)

Riesgo	P	I	Nivel
Inyección SQL en /orders	4	5	20 Alto
Robo de credenciales admin	3	5	15 Alto
Backup expuesto sin cifrado	3	4	12 Medio-Alto

Hallazgo

Los principales riesgos afectan confidencialidad, integridad y disponibilidad; el riesgo inicial supera el apetito definido y requiere tratamiento.
(ISO/IEC 27001:2022)

Fuentes: ISO/IEC 27001:2022; ISO/IEC 27005:2022; NIST CSF 2.0 (2024).

1.4. Gestión de riesgos de seguridad del software

Ejemplo 1 — Tratamiento y medición del riesgo

3. Tratamiento

Inyección SQL:
consultas parametrizadas, WAF, SAST/DAST.

Credenciales admin:
MFA, PAM, vault y revisión de accesos.

Backups:
cifrado, acceso mínimo y prueba de restauración.

(ISO/IEC 27002:2022; NIST SP 800-218, 2022)

4. Medición del riesgo residual

Riesgo	Inicial	Residual	Estado
Inyección SQL en /orders	20	8	Medio
Robo de credenciales admin	15	6	Medio-Bajo
Backup expuesto sin cifrado	12	4	Bajo

Indicadores

- % vulnerabilidades críticas abiertas = 0
- MTTR crítico < 72 h
- Cobertura MFA admins = 100 %
- Restauraciones exitosas = 100 %

Hallazgo

El tratamiento reduce los riesgos a un nivel aceptable y medible dentro del apetito definido.

(NIST SP 800-61r3, 2025)

Fuentes: ISO/IEC 27002:2022; NIST SP 800-218 (2022); NIST SP 800-61r3 (2025).

1.4. Gestión de riesgos de seguridad del software

Ejemplo 2 — Implementación de un SGSI en una plataforma académica

1. Contexto y alcance

Organización:
universidad.

Alcance SGSI:
LMS, expediente estudiantil, SSO y almacenamiento documental.

Activos críticos:
datos personales, calificaciones, exámenes y disponibilidad del portal.

2. Método de análisis

1. Identificar activos, amenazas y vulnerabilidades.
2. Valorar Probabilidad (1–5) e Impacto (1–5).
3. Riesgo inherente = P × I.

(ISO/IEC 27005:2022; NIST CSF 2.0, 2024)

Riesgo	P	I	Nivel
Acceso no autorizado a calificaciones	4	5	20 Alto
Ransomware en servidor académico	3	5	15 Alto
Repositorio cloud mal configurado	3	4	12 Medio-Alto

Hallazgo

Los riesgos comprometen confidencialidad, integridad y disponibilidad; el SGSI debe priorizar controles de acceso, continuidad y monitoreo.
(ISO/IEC 27001:2022)

Fuentes: ISO/IEC 27001:2022; ISO/IEC 27005:2022; NIST CSF 2.0 (2024).

1.4. Gestión de riesgos de seguridad del software

Ejemplo 2 — Tratamiento y medición del riesgo

3. Tratamiento

Calificaciones:
RBAC, MFA y revisión periódica de roles.

Ransomware:
EDR, backups inmutables y segmentación.

Repositorio cloud:
cifrado, CSPM y polítića de acceso.

(ISO/IEC 27002:2022; NIST CSF 2.0, 2024)

4. Medición del riesgo residual

Riesgo	Inicial	Residual	Estado
Acceso no autorizado a calificaciones	20	6	Medio-Bajo
Ransomware en servidor académico	15	8	Medio
Repositorio cloud mal configurado	12	4	Bajo

Indicadores

- Revisión de privilegios = 100 % mensual
- Éxito de restauración >= 95 %
- MTTD < 4 h
- % endpoints con EDR = 100 %

Hallazgo

El riesgo residual queda dentro del umbral aceptable y su seguimiento fortalece la mejora continua del SGSI.

(NIST SP 800-61r3, 2025)

Fuentes: ISO/IEC 27002:2022; NIST CSF 2.0 (2024); NIST SP 800-61r3 (2025).

1.1.5 Propiedades del software seguro y resiliente

Visión general



Un software confiable protege, resiste, se recupera y deja evidencia de su operación.

Fuentes: ISO/IEC 27000:2026; ISO/IEC 27001:2022; ISO/IEC 27002:2022; NIST CSF 2.0 (2024).

1.1.5 Propiedades del software seguro y resiliente

ESPE
UNIVERSIDAD DE LAS FUERZAS ARMADAS
INNOVACIÓN PARA LA EXCELENCIA

Tríada CID

Confidencialidad

La información solo debe ser accesible a usuarios, procesos o sistemas autorizados.

Integridad

Los datos deben mantenerse exactos, completos y sin alteraciones no autorizadas.



Disponibilidad

Los servicios y datos deben estar accesibles cuando se necesiten.

Ejemplo en software: control de acceso + validación + respaldo y alta disponibilidad.

Fuentes: ISO/IEC 27000:2026; ISO/IEC 27001:2022.

1.1.5 Propiedades del software seguro y resiliente

Tríada AAA



Ejemplos: inicio de sesión, RBAC/ABAC y logs de acceso.

Fuentes: ISO/IEC 27002:2022; NIST SP 800-63; NIST CSF 2.0 (2024).

1.1.5 Propiedades del software seguro y resiliente

UNIVERSIDAD DE LAS FUERZAS ARMADAS
INNOVACIÓN PARA LA EXCELENCIA

Técnicas y mecanismos para garantizar las tríadas

Confidencialidad
- Cifrado de la información
- Gestión de secretos
- Autenticación multifactor (MFA)
- Principio de mínimo privilegio

Integridad
- Uso de hashes
- Firmas digitales
- Validación de entradas
- Control de cambios

Disponibilidad
- Redundancia y alta disponibilidad
- Copias de seguridad (backups)
- Monitoreo continuo
- Recuperación ante desastres

Autenticación
- Autenticación multifactor (MFA)
- Federación de identidad
- Gestión de sesiones segura

Autorización
- Control de acceso basado en roles (RBAC) o atributos (ABAC)
- Segregación de funciones
- Políticas de acceso

Auditoría
- Registros de eventos (logs)
- Sistemas de gestión de eventos e información de seguridad (SIEM)
- Alertas y detección de anomalías
- Trazabilidad de acciones

Las técnicas deben aplicarse desde el diseño hasta la operación.

Fuentes: ISO/IEC 27002:2022; NIST SP 800-218 (2022); NIST CSF 2.0 (2024).

1.1.5 Propiedades del software seguro y resiliente

ESPE
UNIVERSIDAD DE LAS FUERZAS ARMADAS
INNOVACIÓN PARA LA EXCELENCIA

Propiedades complementarias



Complementan la seguridad porque facilitan resistir, detectar, recuperar y demostrar confianza.

Fuentes: ISO/IEC 25010; ISO/IEC 27000:2026; NIST CSF 2.0 (2024).

1.1.5 Propiedades del software seguro y resiliente

Buenas prácticas



Diseño seguro

Threat modeling, principios de mínimo privilegio y defensa en profundidad.

Componentes confiables

Evaluar dependencias y aplicar SCA.

Desarrollo seguro

Validación, manejo de errores y revisión de código.

Configuración segura

Hardening, gestión de secretos y mínimos servicios expuestos.

Formación y cultura

Capacitación continua y concienciación del equipo.

Operación y monitoreo

Logs, alertas, backups y respuesta a incidentes.

La seguridad y la resiliencia se construyen durante todo el ciclo de vida del software.

Fuentes: NIST SP 800-218 (2022); ISO/IEC 27002:2022; NIST CSF 2.0 (2024).

ESPE
UNIVERSIDAD DE LAS FUERZAS ARMADAS
INNOVACIÓN PARA LA EXCELENCIA



Gracias por su atención